

Título em Português

Desenvolvimento de um Sistema Seguro de Autenticação, Comunicação e Gestão de Credenciais em Conformidade com a LGPD.

Resumo

Objetivo: Desenvolver uma API REST para autenticação e gestão segura de credenciais, com foco em garantir a conformidade com a Lei Geral de Proteção de Dados (LGPD). **Métodos:** Trata-se de um projeto de desenvolvimento tecnológico realizado no curso de Engenharia de Software da Universidade de Mogi das Cruzes, em 2026. Construída em Java, a aplicação protege os dados em repouso combinando algoritmos de *hashing* e *salting*. O fluxo de acesso conta com Autenticação Multifator (2FA), exigida apenas após a verificação da senha principal. O controle de sessão usa tokens que expiram por inatividade e são invalidados no cliente e no servidor ao sair do sistema. Além disso, aplicou-se a limitação de taxa (*Rate Limiting*) prevenindo ataques de força bruta e mantiveram-se logs de requisição para garantir a rastreabilidade. **Resultados:** A implementação evitou o armazenamento de senhas em texto claro e diminuiu riscos comuns, como o sequestro de sessão e o acesso automatizado indevido. O registro de evidências funcionais mostrou que a arquitetura atende de forma eficiente aos requisitos de auditoria da LGPD. **Conclusão:** A abordagem reforça o princípio de *Privacy by Design* no desenvolvimento de sistemas web. Como recomendação para o avanço da área, sugere-se adaptar essa estrutura para arquiteturas de microsserviços e integrar análises de tráfego em tempo real visando detectar comportamentos anômalos.

Palavras-chave

Segurança da Informação; LGPD; Autenticação Multifator; Criptografia; Gestão de Acesso.

Title in English

Development of a Secure Authentication, Communication, and Credential Management System in Compliance with the LGPD.

Abstract

Objective: To develop a REST API for secure authentication and credential management, focusing on ensuring compliance with the Brazilian General Data Protection Law (LGPD). **Methods:** This technological development project was conducted in the Software Engineering program at the University of Mogi das Cruzes in 2026. Built with Java, the application protects data at rest by combining hashing algorithms and salting. The access flow features Multi-Factor Authentication (2FA), which is required only after verifying the primary password. Session control uses tokens that expire due to inactivity and are invalidated on both the client and server upon logout. Furthermore, Rate Limiting was applied to prevent brute-force attacks, and request logs were maintained to ensure traceability. **Results:** The implementation prevented plaintext password storage and reduced common risks, such as session hijacking and unauthorized automated access. The recording of functional evidence showed that the architecture efficiently meets LGPD audit requirements. **Conclusion:** This approach reinforces the Privacy by Design principle in web system development. For the advancement of the field, we recommend adapting this framework for microservice architectures and integrating real-time traffic analysis to detect anomalous behaviors.

Keywords

Information Security; LGPD; Multi-Factor Authentication; Cryptography; Access Management.

Título en Español

Desarrollo de un Sistema Seguro de Autenticación, Comunicación y Gestión de Credenciales en Conformidad con la LGPD.

Resumen

Objetivo: Desarrollar una API REST para la autenticación y gestión segura de credenciales, con el enfoque de garantizar la conformidad con la Ley General de Protección de Datos (LGPD) de Brasil. **Métodos:** Este proyecto de desarrollo tecnológico se realizó en la carrera de Ingeniería de Software de la Universidad de Mogi das Cruzes en 2026. Construida en Java, la aplicación protege los datos en reposo combinando algoritmos de *hashing* y *salting*. El flujo de acceso cuenta con Autenticación Multifactor (2FA), exigida solo después de verificar la contraseña principal. El control de sesión utiliza tokens que expiran por inactividad y se invalidan en el cliente y en el servidor al cerrar la sesión. Además, se aplicó la limitación de tasa (*Rate Limiting*) contra ataques de fuerza bruta y se mantuvieron registros de peticiones para asegurar la trazabilidad. **Resultados:** La implementación evitó el almacenamiento de contraseñas en texto claro y disminuyó riesgos comunes, como el secuestro de sesión y el acceso automatizado indebido. El registro de evidencias funcionales demostró que la arquitectura cumple eficientemente con los requisitos de auditoría de la LGPD. **Conclusión:** Este enfoque refuerza el principio de *Privacy by Design* en el desarrollo de sistemas web. Como recomendación para el avance del área, se sugiere adaptar esta estructura para arquitecturas de microservicios e integrar análisis de tráfico en tiempo real para detectar comportamientos anómalos.

Palabras clave

Seguridad de la Información; LGPD; Autenticación Multifactor; Criptografía; Gestión de Acceso.